ADVISORY TOOLKIT · BANKS IN QATAR

AI Security Risk Add-on for Banks in Qatar

Guidance for banks that already run an ISO/IEC 27001, ISO/IEC 27005 and ISO 31000 risk process: how to add AI security risk management and the QCB, legal and NCSA requirements on top of it

Version 1.0 - November 2026

Advisory. This add-on offers suggestions to help banks add AI security risk management and the national requirements to their existing ISO/IEC 27001, ISO/IEC 27005 and ISO 31000 process. It does not replace any law, regulation, standard or framework, and it does not interpret QCB or NCSA requirements. The official texts prevail. Each bank remains responsible for its own compliance.

Built with AI assistance; every requirement and citation checked against the QCB and NCSA source texts. Free to use and adapt; please credit the source.

Contents

1. Purpose and who it is for
2. What is required and what is suggested
3. The add-on in three steps
4. Adding AI to the asset-based risk process
5. NIA Standard v2.1 for AI assets
6. Mapping ratings to the national scales
7. Keeping the register live
8. Indicators: KRIs and KPIs
9. Evidencing QCB compliance
10. Reporting to NCSA and QCB
11. A first 90 days for an established bank
12. Points to confirm

- Annex A: Workbook guide
- Annex B: Glossary
- Annex C: References
- Annex D: Worked examples

1. Purpose and who it is for

This add-on is for banks in Qatar that already run an information security risk process built on ISO/IEC 27001, ISO/IEC 27005 and ISO 31000, aligned with QCB requirements. AI changes what that process must cover: new assets (models, training data, prompts, agents), new threats (prompt injection, data poisoning, deepfakes), and new obligations under the QCB Artificial Intelligence Guideline, the Cloud Computing Regulation and the Data Handling and Protection Regulation. NCSA has also published requirements that apply across organisations, including reporting under the EISRMF and the controls of the NIA Standard v2.1.

This add-on helps a bank close those gaps without rebuilding anything. It provides ready-made AI content to load into the existing register, inventory and Statement of Applicability, and a set of requirement sheets to record and evidence compliance.

- **Keep** the bank's method, scales, register, tools and governance.
- **Add** AI assets, threats, vulnerabilities, scenarios, controls, indicators and triggers.
- **Align** ratings to the national bands for reporting to NCSA, and **evidence** QCB, legal and NCSA requirements.

2. What is required and what is suggested

Each requirement in the add-on is labelled by its source and by the strength of the source's own wording, so the bank can separate obligations from good practice.

Source	Strength in the add-on	Basis
QCB AI Guideline, Cloud Computing Regulation, Data Handling and Protection Regulation, Incident Reporting Guideline	Must / Should / May, or Mixed where a row combines them (the regulation's own words)	Banks are regulated by QCB under Law No. 13 of 2012. Sheet 9A lists 71 obligations relevant to AI, verified against the texts.
QCB Technology Risks circular (January 2018)	Cited by section number	The add-on cites section numbers, and states only the two timelines needed for the reporting calendar (8.2.10 and 7.1.1).
Laws of Qatar	Law	Law No. 13 of 2016 (personal data) and Law No. 20 of 2019 (AML/CFT), where relevant to AI.
EISRMF and NISRMF (NCSA)	REQUIRED: reporting; RECOMMENDED: adopting the full framework	'Adoption of a risk framework is strongly encouraged. Reporting to NCSA is mandatory.' (NISRMF). The NISRMF describes the four deliverables as every organisation's obligations under Amiri Decree No. 1 of 2021, Article 3.

Source	Strength in the add-on	Basis
NIA Standard v2.1 (NCSA)	REQUIRED: classification first; baseline (*) controls; additional controls for higher ratings	'This standard applies to all Organizations'; baseline controls 'are mandatory and must be implemented' (2.2, 2.3).
National Data Classification Policy v3.0 (NCSA)	REQUIRED (confirm with QCB and NCSA)	'The policy mandates that organizations within the scope of this policy, classify their data' (10.3). Its scope is 'in coordination with sector regulator'; QCB DHP 6.1-6.2 asks for a classification policy based on leading practice and says a bank 'may' use the national policy.
ECCMF v1.0 (NCSA)	CONDITIONAL for Critical National Organisations; RECOMMENDED otherwise	CNO compliance 'will be monitored by sector regulators'; others 'are also encouraged to adopt'.
National Incident Management Framework (NIMF) (NCSA)	Reference (restates the NIA two-hour rule)	Restates that organisations 'must report critical cyber incidents to the NCSA within two hours of identification' (4.1); NCSA assigns the national incident category (1.6, 4.1).
National Cyber Crisis Management Framework (NCCMF) v1.0 (NCSA)	Reference only	National crisis management; the NIMF describes it as providing 'the national cyber crisis management capability beyond the NIMF' (1.6). No bank duties are taken from it.
ISO/IEC 27001 and 42001; ISO/IEC 27005 and ISO 31000	Good practice (the bank's chosen method)	ISO/IEC 27001 and 42001 cited by clause number; ISO/IEC 27005 and ISO 31000 cited by name.
OWASP Top 10 for LLM Applications 2026; OWASP Top 10 for Agentic Applications 2026	Good practice (threat references)	Threats in sheet 2 cite OWASP entry IDs and names (OWASP GenAI Security Project).
Qatar 2022 Cybersecurity Framework (QCSF)	GOOD PRACTICE	Issued in 2018 for entities in the 2022 World Cup ecosystem; used for capability mapping only.

Where a source does not say how it is enforced for banks (for example, the cycle for submitting the risk register to NCSA), the add-on shows 'Confirm with' rather than assuming.

3. The add-on in three steps

Step	What the bank does	Sheets	Result
1. Add AI content	Add AI asset types to the asset inventory or IAR; select the scenarios that apply and rate them on the bank's own scale; add the applicable AI controls to the SoA; adopt indicators and triggers; add the minimum fields.	1-8	AI risks in the existing register, controls in the SoA
2. Map ratings to national bands	Map each of the bank's rating labels to a national EISRMF band. The national band and the out-of-band flag then appear for every scenario.	9B, 4	Consistent High and Severe identification for NCSA
3. Evidence compliance	Record status and evidence for QCB, national, NIA and legal requirements; track submissions; report the summary.	5A, 5B, 9A-9C, 10, 11	A compliance view the bank can show to its board, QCB and NCSA

The workbook has three layers. Start with sheet 0 Essentials: 13 actions whose source wording is mandatory (QCB "must", NCSA REQUIRED or NIA baseline); E12 also includes the QCB "should" timeframes of Incident Reporting Guideline 6.2. The working sheets (1-8 and 10) hold the content to load into the bank's existing process; fields and calendar rows are tagged Essential or Recommended, and scenarios and controls show whether they link to mandatory QCB requirements. Sheets 5B, 9A, 9B and 9C are the reference layer with the full requirement detail for evidence and audit. Every REQUIRED and Must row applies wherever it sits.

4. Adding AI to the asset-based risk process

The add-on follows the ISO/IEC 27005 asset-based approach: asset, threat, vulnerability, consequence. Each element has its own sheet, and the 42 scenarios in sheet 4 combine them.

AI assets (sheet 1)

Ten AI asset types cover models, training data, chatbot interfaces, knowledge bases, AI APIs and cloud services, AI features inside vendor products, agents, prompts and guard rails, outputs and logs, and public AI tools. Most are secondary (supporting) assets; the business process and the information they serve are the primary assets. Record both, so that a risk to an AI component is linked to what the bank actually needs to protect.

Threats and vulnerabilities (sheets 2 and 3)

Sheet 2 lists 24 AI threats; where the OWASP Top 10 for LLM Applications 2026 or the OWASP Top 10 for Agentic Applications 2026 covers a threat, its entry is given. Sheet 3 lists 25 vulnerabilities that make those threats possible, how to detect them, and the controls that address them.

Scenarios (sheet 4)

Each scenario states what could happen, to which asset, through which path and with what consequence, and names the main consequence area. The add-on also lists the suggested controls, the NIA baseline statements those controls support, the QCB requirements involved and the ISO/IEC 27001 Annex A controls. The bank decides which scenarios apply, assigns an owner and rates them with its own scales.

- Copy only the scenarios that apply; adapt the wording to the bank's systems.
- Use the bank's existing likelihood and impact scales; the national band is calculated from the mapping in 9B.
- A scenario rated High or Severe on the national band needs out-of-band reporting to NCSA (section 6).

Controls (sheet 5)

Sheet 5 provides 31 AI controls (20 core and 11 bank-specific), each with what good looks like and the evidence expected. Each control is mapped, where a match exists, to ISO/IEC 27001 Annex A for the Statement of Applicability, and to ISO/IEC 42001, NIA v2.1, QCSF, the QCB requirement rows and the Technology Risks circular sections. The bank marks each control as applicable or not and records implementation status and evidence.

5. NIA Standard v2.1 for AI assets

The NIA Standard states that it 'applies to all Organizations and their corresponding information assets'. AI assets are information assets, so the same rules apply to them:

1. **Classify first.** Using the National Data Classification Policy 'is a mandatory step before attempting to apply the controls' (2.3 a). Sheet 5A records the confidentiality, integrity and availability rating of each AI system.
2. **Baseline controls.** Assets rated 1 or above 'require compliance to all control statements that are baseline at minimum' (2.3 c). NIA v2.1 has 166 baseline statements, marked * in the standard and 'Yes' in sheet 5B.
3. **Additional controls.** Assets rated 2 need one or more additional controls per applicable domain, and assets rated 3 or above need two or more, chosen through risk assessment (2.3 d-e). Sheet 5A shows which applies to each AI system.
4. **Priority.** Implementation priority should be based on the aggregate level, with High first (2.3 f).

Sheet 5B lists all 356 statements with their domain, whether they are baseline, how they apply to AI assets, and which add-on controls support them. The bank records status and evidence for its AI assets. Statements are listed by number only; read each one in the NIA Standard v2.1 published by NCSA.

NIA v2.1 numbers two statements 'PH 2' and has no PH 1; the add-on shows them as PH 2 (first) and PH 2 (second).

6. Mapping ratings to the national scales

The EISRMF does not ask a bank to replace its framework. It states that organisations that already run one 'adopt the components required for national consistency and align their scoring

to the national scales'. The add-on does this with a mapping table in 9B: the bank lists its own rating labels and selects the matching national band for each.

National band	Score range (likelihood x consequence)	Reporting
Very Low	1-2	Regular cycle
Low	3-4	Regular cycle
Medium	5-8	Regular cycle
High	9-15	Notify NCSA immediately; detailed report within 48 hours
Severe	16-25	Notify NCSA immediately; detailed report within 48 hours

The add-on applies out-of-band reporting to NCSA for High and Severe risks, in line with the EISRMF reporting section (pp. 20-24) and the NISRMF (pp. 14, 15, 22). Confirm with NCSA whether the inherent or residual rating applies; the add-on uses the current rating.

The score ranges are read from the national risk matrix in the NISRMF (Figure 7), where every likelihood and consequence pair falls within them; they agree with the EISRMF example that likelihood 4 x consequence 3 = 12 is High. The 48-hour report covers the risk description and severity, the potential impact on critical assets or infrastructure, current mitigation efforts and any support requested from NCSA (NISRMF).

9B also includes a crosswalk from the content of the national registers (Information Asset Register, Information Security Risk Register, Annual Risk Treatment Plan and the 48-hour report) to typical ISO/IEC 27005 register fields, so the bank can confirm that its existing templates can produce what NCSA receives.

7. Keeping the register live

Sheet 7 lists the inputs that should feed the register and trigger reassessment: AI incidents, data breaches, test and red-team findings, KRIs at red, threat intelligence, significant changes, vendor AI changes, audit and QCB findings, supplier assessments, exercises, complaints and changes in law or regulation. Reassessment times are placeholders; NCSA and QCB deadlines take precedence.

- **Material change.** The NISRMF asks for the register to be reviewed whenever a material change occurs, as well as at least every six months.
- **Intelligence from NCSA.** The NISRMF states that 'Intelligence shared with an organization must be recorded in that organization's risk register' and reflected in its treatment plan.
- **Vendor AI changes.** A provider adding an AI feature or replacing a model is a change: assess it before use. If the bank acts as Provider (AI Guideline 14.3), check whether it is a material modification that needs QCB approval (11.1).
- **Incidents.** Where NIA controls and other regulations overlap, the NIA Standard asks organisations to comply with both or with whichever gives the higher degree of security. Incidents go to QCB under its Incident Reporting Guideline (High cyber or technology incidents within 1 hour, Medium within 4 hours) and critical incidents to NCSA within two

hours (NIA IM 8); the Technology Risks circular (8.2.10) also sets 1 hour for critical incidents to QCB and the relevant governmental authorities (whether this covers NCSA is an open point). Data breaches are reported as incidents to QCB and also to NCSA and the Ministry of Interior (DHP 16.1-16.3). An incident at an AI provider that affects the bank is reported to QCB by the bank (Incident Reporting Guideline 6.3 bullet 10). An incident that escalates to a crisis follows the bank's crisis plan in line with the ECCMF.

8. Indicators: KRIs and KPIs

Sheet 6 provides 13 KRIs and 12 KPIs. KRIs show changes in exposure (for example unregistered AI services, blocked sensitive uploads, drift, detected deepfake attacks); KPIs show control performance (for example AI systems assessed, NIA baseline statements implemented, incidents reported on time). Each has a formula, data source, frequency and suggested amber and red thresholds; the status is calculated when the current value is entered. Thresholds marked 'set from baseline' should be set after a few months of measurement.

9. Evidencing QCB compliance

Sheet 9A lists the obligations relevant to AI from four QCB instruments, verified against the official texts, with clause numbers, the regulation's own wording level and scope, and the add-on controls that support each.

Instrument	Rows	Key points for AI
Artificial Intelligence Guideline (in force 4 September 2024)	40	AI Register (10.7) and annual disclosure (10.6); high-risk classification (9.6-9.7); QCB approval before Provider launch, material change or high-risk agreements (11); human oversight (13); model security including prompt injection (17.4-17.7); serious incident reporting (19.5); customer notice, explanation and recourse (20-21).
Cloud Computing Regulation (in force 15 April 2024)	11	QCB approval before a cloud arrangement (21.5); approval before signing material arrangements (13.4); PII and financial information processed in Qatar only (21.4); Cloud Register (9).
Incident Reporting Guideline (2024; exact date to confirm)	8	Triage with QCB priorities, High assumed until downgraded (6.1); High cyber or technology incidents within 1 hour, Medium within 4 hours, other High within 4 hours (6.2); Hotline first, initial report content, updates, final report within 3 days of resolution (6.3); monthly consolidated report within 7 days of month end (6.2-6.3); incidents reported to other authorities and incidents at third parties also reported to QCB (6.3).
Data Handling and Protection Regulation (effective 16 February 2025)	12	Classification (may use the National Data Classification Policy, 6.2); ROPA (6.4); PIA (10.4); privacy assessment for autonomous processing (13.4); QCB approval for fully autonomous decision-making (13.5); foreign storage approval (15.1); breach reporting (16.3).

Each row keeps the regulation's own wording level. A row marked Mixed combines clauses with different wording and contains at least one "must" clause; the "Wording by clause" column lists which clauses are "should", "may" or "will". The DHP itself states that "must" is obligatory and "may" is advisory (DHP 3).

For each row the bank records status, evidence and owner. The compliance summary (sheet 11) counts status for Must rows and Mixed rows separately.

10. Reporting to NCSA and QCB

A bank reports along two lines: to QCB as its regulator and to NCSA as the national cyber security authority. Each line has its own triggers, timelines and severity scale, and one event can need reports on both.

Line	What is reported	Source
QCB	Incidents by QCB priority (1 hour / 4 hours / monthly consolidated report; final report within 3 days of resolution); critical incidents within 1 hour; serious AI incidents; data breaches; annual AI Register, Cloud Register and Technology Risks compliance report; approvals and notifications before launch or signing	Incident Reporting Guideline 6.2-6.3; Technology Risks circular 8.2.10, 7.1.1; AI Guideline 10.6, 11, 13.6.1, 19.5; Cloud Regulation 9.4, 13.4, 21.5; DHP 13.5, 15.1, 16.1-16.3
NCSA	Critical incidents within 2 hours (1 hour suggested until confirmed whether Technology Risks circular 8.2.10 applies); High and Severe risks out of band (immediately, detailed report within 48 hours); Information Security Risk Register, Annual Risk Treatment Plan and attestation; data breaches	NIA v2.1 IM 8; NIMF 4.1; EISRMF; NISRMF; DHP 16.3

Where the two lines meet:

- **One incident, two reports.** Two rules apply to a critical cyber incident: the Technology Risks circular (8.2.10) sets 1 hour for reporting to QCB and the relevant governmental authorities, and NIA v2.1 (IM 8) sets 2 hours for reporting to NCSA. Whether NCSA is one of those authorities is an open point to confirm with QCB and NCSA; until then, reporting to NCSA within 1 hour is the cautious option. The Incident Reporting Guideline states that an incident reported to any authority must also be reported to QCB, and the NIA Standard asks organisations to comply with both requirements where they intersect.
- **Different scales.** QCB rates incidents High, Medium or Low under its own scheme; NIA v2.1 refers to Critical incidents without defining the term; the EISRMF bands (Very Low to Severe) rate risks, not incidents. Sheet 10 sets out the scales and a suggested way to apply them together; no official mapping is published.
- **Submitted to NCSA.** EISRMF and NISRMF deliverables are submitted by the bank to NCSA. Still to confirm with NCSA: the submission cycle and how NIA is enforced for banks.

Scale	Levels	Used for	Source
QCB incident priority (cyber and technology-related)	High / Medium / Low; High assumed until downgraded	Incident reports to QCB: 1 hour / 4 hours / monthly	QCB Incident Reporting Guideline 6.1.1, 6.2
QCB incident priority (other operational)	High (one or more impact conditions, e.g. >1% of customers or transactions) / Medium-Low	Incident reports to QCB: 4 hours / monthly	QCB Incident Reporting Guideline 6.1.2, 6.2
Critical incident (QCB)	Critical	QCB and relevant governmental authorities within 1 hour	Technology Risks circular 8.2.10
Critical incident (NIA)	Critical - not defined in NIA v2.1 (its Major Change Tracker, 8.3, records that the appendix on incident management criticality classification was removed); incidents are categorised and prioritised by type of attack and criticality of impacted systems (IM 6)	Incident reports to NCSA within 2 hours	NIA v2.1 IM 6, IM 8; NIMF 4.1
NCSA national incident category	Red (nationally coordinated) / Orange (sectorally coordinated) / Yellow (locally coordinated) / White (no national significance)	Assigned by NCSA to confirmed incidents, based on severity, spread, urgency and national impact; independent of the bank's internal classification	NIMF 1.6, 4.1
National risk band	Very Low / Low / Medium / High / Severe	Risks, not incidents: High and Severe reported to NCSA out of band (immediately; detailed report within 48 hours)	EISRMF; NISRMF

Who signs what

The two registers sent to the authorities have different sign-off rules:

Register	What the source says	Source
QCB AI Register	Disclosed to QCB annually and on request. No signatory is named. The Board and senior management remain accountable for the outcomes and decisions of AI systems; roles must be clearly allocated between model owners, developers and approvers.	AI Guideline 10.6, 7.1, 8.2.3
NCSA Information Security Risk Register	Reviewed internally at least every six months and submitted to NCSA. The attestation of adoption is submitted annually by the President or equivalent (EISRMF); it is signed and sent with copies of the risk register and treatment plan (NISRMF).	EISRMF, Reporting to NCSA; NISRMF, What organizations owe

A suggested sign-off chain that satisfies both, and ISO/IEC 27001:

1. AI system owners confirm that their AI Register entries are accurate and complete (suggested practice).
2. Risk owners approve the risk treatment plan and accept residual risk (ISO/IEC 27001 6.1.3: required for conformity).
3. The AI oversight / risk function reviews and consolidates both registers (suggested practice; AI Guideline 7.4-7.5 on the function overseeing AI).
4. Senior management approves the QCB disclosure and the Board is informed (suggested practice; AI Guideline 7.1, 7.3.4).
5. The President or equivalent submits the NCSA attestation (EISRMF; NISRMF).

Keep each register as a working file and each disclosure as a dated, approved snapshot (ISO/IEC 27001 and 42001, 7.5 Documented information). Sheet 8 lists the fields and sheet 10 the internal sign-off date.

Governance settings (sheets 8A and 8B)

Sheet 8A holds the bank's own approval and escalation settings next to the published EISRMF text. The bank sets the approvers, acceptance periods, appetite and who holds each decision level; the EISRMF meaning of each band, the NCSA reporting rule and the EISRMF decision-making levels are given as fixed text.

- **By band.** For each national band: the approver for treatment and residual-risk acceptance (in addition to the risk owner) and the maximum acceptance period, set by the bank; what the band means (EISRMF Figure 5); and out-of-band reporting to NCSA for High and Severe risks (EISRMF; NISRMF).
- **Risk appetite.** For each consequence area, the highest band the bank accepts. Sheet 4 compares each scenario's current band with it and shows "Above appetite" when it is exceeded; the EISRMF prioritises risks above appetite for treatment.
- **Decision-making authority.** Strategic (Executive Management or Board), tactical (CISO or relevant business owners) and operational (designated individuals), as in EISRMF Figure

3; the bank names who holds each level. The same figure describes an Information Security Governance Committee (ISGC) and a Risk Management Committee; map them to the bank's existing committees.

- **Acceptance log (8B).** One row per accepted risk, with the risk owner and the date they accepted it (ISO/IEC 27001 6.1.3). The approver required and the review date come from 8A; an approver role different from 8A is flagged "Check", and expired or incomplete acceptances are flagged.
- **Example.** Approval authority usually rises with the band, for example from the information security function to senior management and then the Board or a Board committee. The Board and senior management remain accountable for AI (QCB AI Guideline 7.1), and senior management keeps the Board informed (7.3.4).
- **Review.** Review these settings when the bank's policy, QCB regulations or NCSA publications change.

Submission calendar (sheet 10)

Deliverable	To	When	Source
Information Asset Register review	Internal / NCSA	Annual. Include AI assets.	EISRMF
Information Security Risk Register - internal review	Internal	Every 6 months. At least every six months, and whenever a material change occurs (NISRMF).	EISRMF; NISRMF
Information Security Risk Register - submission	NCSA	Annual. Submitted to NCSA; the NISRMF links it to the annual attestation and treatment plan. Confirm the cycle with NCSA.	EISRMF; NISRMF
Annual Risk Treatment Plan	NCSA	Annual. Reviewed and updated at least annually.	EISRMF
Attestation of adoption	NCSA	Annual. Submitted annually by the President or equivalent, confirming the risk assessment, treatment plan and controls (EISRMF); signed and sent with copies of the risk register and treatment plan (NISRMF).	EISRMF; NISRMF

Deliverable	To	When	Source
AI Register sign-off (internal, before the QCB disclosure)	Internal	Annual. Suggested sequence: AI system owners confirm entries; risk owners approve treatment and accept residual risk; the AI oversight / risk function consolidates; senior management approves; the Board is informed. Lead time set by the bank.	AI Guideline 7.1, 7.3.4, 8.2.3; ISO/IEC 27001 6.1.3
Notification that a high-risk AI system without human oversight is being considered	QCB	Event-driven. As soon as such a system is being actively considered or developed.	AI Guideline 13.6.1
Out-of-band report of a High or Severe risk	NCSA	Event-driven. Notify immediately; detailed report within 48 hours.	EISRMF
Critical incident report	NCSA	Event-driven. Within two hours of identification (NIA IM 8; NIMF 4.1 restates it). Open point: whether the 1-hour rule in Technology Risks circular 8.2.10 also applies to NCSA; 1 hour suggested until confirmed.	NIA v2.1 IM 8; NIMF 4.1
Critical incident report	QCB and relevant authorities	Event-driven. Within one hour of identification.	Technology Risks circular 8.2.10
Cyber or technology incident - High priority	QCB (Hotline)	Event-driven. Within 1 hour of discovery; report first through the QCB Incident Reporting Hotline. High is assumed until downgraded (6.1.1).	Incident Reporting Guideline 6.2; 6.3 bullet 1
Cyber or technology incident - Medium priority	QCB (Hotline)	Event-driven. Within 4 hours of discovery.	Incident Reporting Guideline 6.2; 6.3 bullet 1
Other operational incident - High priority	QCB (Hotline, Supervision Sector)	Event-driven. Within 4 hours of discovery.	Incident Reporting Guideline 6.2; 6.3 bullet 1

Deliverable	To	When	Source
Incident updates	QCB	Event-driven. At every significant milestone within the incident.	Incident Reporting Guideline 6.3 bullet 3
Final incident report (Annexure I)	QCB	Event-driven. Within 3 days from the date of resolution.	Incident Reporting Guideline 6.3 bullet 4
Monthly consolidated incident report (Annexure II)	QCB Supervision Sector and Information Security Department	Monthly. Within 7 days from the end of each month (next due = end of the month of the last submission + 7 days; assumes each report is submitted in the month after the month it covers); includes Low cyber or technology incidents and Medium-Low other incidents.	Incident Reporting Guideline 6.2; 6.3 bullets 5-7
Serious AI incident report	QCB	Event-driven. Immediately after a causal link, or its reasonable likelihood, is established ('should').	AI Guideline 19.5
Data breach or data privacy breach	QCB, NCSA, Ministry of Interior	Event-driven. Classified as an incident and reported as per QCB's incident reporting guidelines (16.1-16.2; see the QCB Incident Reporting Guideline); also to NCSA and the Ministry of Interior (16.3).	DHP 16.1-16.3
AI Register disclosure	QCB	Annual. Also on request.	AI Guideline 10.6
Cloud Register disclosure	QCB	Annual. Also on request.	Cloud Regulation 9.4
Annual assessment of each cloud arrangement	Internal	Annual. Includes review of contracts in the Cloud Register.	Cloud Regulation 15.1
ROPA review	Internal	Annual. Or when triggered by change.	DHP 6.4.1
Data map review	Internal	Annual. Annual review of data maps, including AI data flows.	DHP 6.5.1

Deliverable	To	When	Source
Technology Risks compliance report	QCB	Annual. Annual at a minimum.	Technology Risks circular 7.1.1

Sheet 10 calculates due dates from the date last submitted. EISRMF and NISRMF deliverables are submitted to NCSA; confirm the submission cycle with NCSA.

11. A first 90 days for an established bank

Period	Focus
Days 1-30	Assign an owner to each of the 13 essentials (sheet 0). Compare the bank's templates with sheet 8 and the 9B crosswalk; add missing fields. Complete the scale mapping in 9B. Add AI asset types to the inventory and rate AI systems in 5A. Set up the direct reporting line to NCSA.
Days 31-60	Set the governance values (8A) and start the acceptance log (8B). Select and rate applicable scenarios (4) in the existing register. Mark applicable controls (5) in the SoA. Record NIA baseline status for AI assets (5B). Record QCB status and evidence (9A), focusing on 'Must' rows and approvals.
Days 61-90	Start the indicators (6) and triggers (7). Report High and Severe AI risks to NCSA if any. Present the compliance summary (11) to management and plan remaining gaps in the Annual Risk Treatment Plan.

12. Points to confirm

5 points need confirmation from QCB or NCSA:

- Out-of-band reporting: the add-on applies out-of-band reporting to NCSA for High and Severe risks, in line with the EISRMF reporting section (pp. 20-24) and the NISRMF (pp. 14, 15, 22). Confirm with NCSA whether the inherent or residual rating applies; the add-on uses the current rating.
- Critical National Organisation status: the NIMF and the ECCMF define CNOs (the NIMF: 'organisations that offer critical services in the State of Qatar') but publish no list, and the EISRMF states that this classification is determined centrally through a defined process overseen by NCSA. Each bank should confirm its status with NCSA or QCB. If a bank is a CNO, its ECCMF compliance 'will be monitored by sector regulators' (ECCMF).
- The QCB Incident Reporting Guideline defines the Sector-Specific Security Regulation as 'QCB Information Security regulations that are applicable to Entities from a specific subsector within the financial sector in Qatar'. Which document is the Sector-Specific Security Regulation for banks (AI Guideline 17.1, 24.1.1) should be confirmed with QCB.
- The QCB Incident Reporting Guideline is understood to have been issued in 2024, but the copy reviewed shows no date; confirm the exact date and circular number with QCB.

- Critical incident deadline for NCSA: the Technology Risks circular (8.2.10) requires critical incidents to be reported to QCB and the relevant governmental authorities within 1 hour of identification; NIA v2.1 IM 8 sets two hours for NCSA. Neither text says whether NCSA is one of those authorities. Suggested option until confirmed: report to NCSA within 1 hour. Confirm with QCB and NCSA.

Notes:

- The consequence areas Legal and regulatory compliance, Financial (organisation), Operational (organisation) and Reputation (organisation) in sheet 4 are additions to the six NISRMF national consequence dimensions; align them with the bank's own impact categories.
- Neither QCB nor NCSA publishes a mapping between QCB incident priorities (High / Medium / Low) and NIA v2.1 Critical incidents (IM 8); the mapping note in sheet 10 is a suggestion for the bank's incident procedure.
- NIA v2.1 numbers two statements 'PH 2' and has no PH 1; they are shown as PH 2 (first) and PH 2 (second).

Annex A: Workbook guide

Sheet	Purpose	Bank completes
Start Here	Purpose, three steps, three layers, strength legend, colours.	-
0 Essentials	13 mandatory actions to start with (E12 also includes QCB "should" timeframes).	Status, owner, date, evidence
1 AI Asset Types	AI assets with classification guidance and fields.	Add to inventory
2 AI Threats	Threat catalogue with OWASP LLM and Agentic Top 10 references.	-
3 AI Vulnerabilities	Weaknesses, detection and fixes.	-
4 Risk Scenarios	42 scenarios with controls, NIA, QCB and ISO links.	Applicability, owner, ratings, treatment, status
5 AI Controls	31 controls with full mappings.	Applicability, status, evidence, owner, date
5A NIA by AI System	NIA requirements per AI system from its ratings.	AI systems and C, I, A ratings
5B NIA for AI	All 356 NIA statements applied to AI assets.	Status and evidence
6 KRIs and KPIs	Indicators with thresholds.	Current values
7 Inputs and Triggers	Inputs, reassessment times, escalation, where to record each one and the date to enter.	Reassessment times
8 Fields to Add	Minimum fields with requirement source.	Already in template?

Sheet	Purpose	Bank completes
8A Governance Settings	Approver and acceptance period per band, with EISRMF meaning and NCSA reporting; appetite per area; decision-making authority.	Approvers, periods, appetite, who holds each level
8B Risk Acceptance Log	Accepted risks with risk owner, approver check, review date and status.	One row per acceptance
9A QCB Requirements	71 QCB obligations relevant to AI.	Status, evidence, owner
9B National Requirements	NCSA requirements plus the QCSF (good practice), scale mapping, crosswalk.	Status, evidence, mapping, field names
9C Laws	Laws relevant to AI.	Status, evidence
10 Reporting Calendar	NCSA and QCB submissions; severity scales.	Last submitted dates
11 Compliance Summary	Status counts.	-
References	Sources and open points.	-

Annex B: Glossary

Term	Meaning in this add-on
AI agent	Software that uses a model to plan and carry out actions through tools, APIs or other systems.
Aggregate level	Low, Medium or High: the classification level from the C, I and A ratings in the National Data Classification Policy matrix (Table 1); NIA v2.1 2.3 f calls it the aggregate security level.
Baseline control (NIA)	A control statement marked * in NIA v2.1; mandatory for assets rated 1 or above.
Cloud arrangement (QCB)	Any arrangement with a cloud service provider, or with a third party that uses one in the services it provides (Cloud Regulation, definitions).
Deepfake	Synthetic audio, image or video made to imitate a real person.
IAR	Information Asset Register (EISRMF).
ISRR	Information Security Risk Register (EISRMF).
National band	Very Low, Low, Medium, High or Severe on the national EISRMF scales.
Out-of-band report	Immediate notification to NCSA of a High or Severe risk, with a detailed report within 48 hours.
PIA	Privacy Impact Assessment (DHP 10.4).

Term	Meaning in this add-on
Primary / secondary asset	Primary assets are business processes and information; secondary assets are the systems that support them.
Prompt injection	Instructions hidden in input or content that make an AI system ignore its intended behaviour.
ROPA	Record of Processing Activities (DHP 6.4).
SoA	Statement of Applicability (ISO/IEC 27001 6.1.3).

Annex C: References

Document	Issuer	Status
QCB Artificial Intelligence Guideline	Qatar Central Bank	In force 4 September 2024; verified against the official text
QCB Cloud Computing Regulation	Qatar Central Bank	In force 15 April 2024; verified
QCB Data Handling and Protection Regulation	Qatar Central Bank	Effective 16 February 2025 (date not shown on the copy reviewed)
QCB Incident Reporting Guideline - Reporting Incidents by QCB-regulated Entities	Qatar Central Bank	Verified against the copy provided; understood to be issued in 2024 (date not shown on the copy) - confirm exact date and circular number
QCB Technology Risks circular (January 2018)	Qatar Central Bank	Cited by section number; two timelines stated (8.2.10, 7.1.1)
Enterprise Information Security Risk Management Framework (EISRMF) v1.0	NCSA	2026; verified
National Information Security Risk Management Framework (NISRMF) v1.0	NCSA	2026; verified
National Information Assurance Standard v2.1	NCSA	May 2023; cited by statement number and baseline flag only (verified); statement text is not reproduced
National Data Classification Policy v3.0	NCSA	May 2023; verified

Document	Issuer	Status
Enterprise Cyber Crisis Management Framework (ECCMF) v1.0	NCSA	2025; verified
National Incident Management Framework (NIMF)	NCSA	Public Version (no date shown on the copy); verified
National Cyber Crisis Management Framework (NCCMF) v1.0	NCSA	2025; reference only (national crisis management)
Qatar 2022 Cybersecurity Framework (QCSF) v1.0	Supreme Committee for Delivery & Legacy	5 August 2018; scope: World Cup ecosystem entities; good practice reference
Law No. 13 of 2016 on Personal Data Privacy Protection	State of Qatar	Law
Law No. 20 of 2019 on Combating Money Laundering and Terrorism Financing	State of Qatar	Law
Law No. 13 of 2012 (QCB Law)	State of Qatar	Law
ISO/IEC 27001:2022; ISO/IEC 27005:2022; ISO 31000:2018	ISO / ISO/IEC	ISO/IEC 27001 cited by clause number; ISO/IEC 27005 and ISO 31000 cited by name
ISO/IEC 42001:2023	ISO/IEC	Cited by clause number only
ISO/IEC 27090 Cybersecurity - Artificial intelligence (AI) - Addressing security threats and compromises to AI systems	ISO/IEC	Listed for reference; not mapped in this version; mapping planned for a later version once verified against the official text
OWASP Top 10 for LLM Applications 2026	OWASP GenAI Security Project	Version 2026, dated 4 August 2026; cited by entry ID and name in sheet 2
OWASP Top 10 for Agentic Applications 2026	OWASP GenAI Security Project	Version 2026, December 2025; cited by entry ID and name in sheet 2

Annex D: Worked examples

Three AI systems taken end to end through the workbook. Ratings, bands, appetite levels and approvers are examples; each bank uses its own scale and its own values in 8A.

D.1 Customer service chatbot (AS22)

Step	Example
AI system (5A)	AI-03 Customer service chatbot (AA03): rated C3 Secret / Confidential, I2, A2; aggregate level High. NIA v2.1: all baseline (*) statements apply, plus two or more additional controls per applicable domain, by risk assessment (2.3). The chatbot can show card and account data, and its transcripts and logs (AI-07, AA09) hold the same data. DHP 7.3 requires SPI and SFI to be classified and managed 'as per the highest, most strict classification available'. This example assumes C3 is the highest tier in use (substitute the actual top tier), so both are rated C3 in 5A.
Scenario (4)	AS22 (asset type AA09 AI outputs, decisions and logs): Chatbot transcripts containing card and personal data are stored in an unprotected log. Threat AT08 Sensitive information in output or logs; vulnerability AV18 Prompts, outputs and logs stored without adequate protection. Main consequence area: Legal and regulatory compliance.
Rating (example)	The bank rates the risk on its own scale; the mapping in 9B gives the national band High. High and Severe risks are reported to NCSA out of band: notify immediately, detailed report within 48 hours (EISRMF).
Approval and appetite (8A)	EISRMF meaning of High: Immediate intervention. Treatment plan required. Approver: the role the bank set for High in 8A, in addition to the risk owner. If the bank set Medium as the highest acceptable band for Legal and regulatory compliance, sheet 4 shows "Above appetite" and the risk is escalated to the decision level the bank set in 8A (section C).
Treatment (5)	Mitigate with C17 AI logging and security monitoring, C06 Data classification and privacy for AI, C16 Protection of models and AI data. QCB rows supported: Q30 (17.8-17.9); DH04 (7.1-7.9); DH05 (8-9); DH12 (16-17). NIA baseline (*) statements supported: AM 3; CY 3, 5-7, 12; DL 1-3; DR 1-2; SM 1-2, 4, 7; VL 8.
Residual risk, acceptance and monitoring (8B, 6)	Target residual band Low (example). The risk owner approves the treatment plan and accepts the residual risk (ISO/IEC 27001 6.1.3); record it in 8B with the risk owner, the approver set for Low and the review date from the period set in 8A. Sheet 4 tracks the treatment target date; overdue High or Severe treatments feed K13. Indicators (6): P11 AI systems sending logs to security monitoring; K13 Open High or Severe AI risks past their treatment date. Row RA-01 in 8B is this example.

Step	Example
If it happens (10)	If card or personal data is exposed, it is a data breach: report it as an incident to QCB, and also to NCSA and the Ministry of Interior (DHP 16.1-16.3). Treat a cyber incident as High until downgraded (Incident Reporting Guideline 6.1.1): QCB Hotline within 1 hour (6.2-6.3). A critical incident goes to QCB and the relevant governmental authorities within 1 hour (Technology Risks circular 8.2.10) and to NCSA within 2 hours (NIA IM 8); whether 8.2.10 covers NCSA is an open point (1 hour suggested until confirmed).

D.2 Retail credit scoring model (AS13)

Step	Example
AI system (5A)	AI-04 Retail credit scoring model (AA01): rated C3 Secret / Confidential, I3, A2; aggregate level High. NIA v2.1: all baseline (*) statements apply, plus two or more additional controls per applicable domain, by risk assessment (2.3). Rated at least as high as the most sensitive data used to train or run it (sheet 1, AA01); credit data is SFI, so C3 is used as the highest tier in this example (substitute the actual top tier). High integrity because it drives credit decisions.
Scenario (4)	AS13 (asset type AA01 AI model): The credit scoring model disadvantages a customer group, and declines cannot be explained. Threat AT16 Unfair or biased outcomes; vulnerability AV12 No fairness or bias testing across customer groups. Main consequence area: Legal and regulatory compliance.
Rating (example)	The bank rates the risk on its own scale; the mapping in 9B gives the national band Medium. No out-of-band report to NCSA is needed for this band.
Approval and appetite (8A)	EISRMF meaning of Medium: Treat where above appetite; otherwise manage by control. Approver: the role the bank set for Medium in 8A, in addition to the risk owner. If the bank set Medium as the highest acceptable band for Legal and regulatory compliance, sheet 4 shows "Within appetite".
Treatment (5)	Mitigate with CB01 Model risk management for AI, C12 Testing and performance monitoring, C13 Human oversight and explanation, CB03 Customer transparency, explanation and recourse. QCB rows supported: Q06 (7.7-7.12); Q09 (9.6-9.7); Q25 (15.3-15.15); Q35 (20.4-20.8, 20.10-20.11); Q37 (21.1-21.3). NIA baseline (*) statements supported: AC 4; RM 1-2.
Residual risk, acceptance and monitoring (8B, 6)	Target residual band Low (example). The risk owner approves the treatment plan and accepts the residual risk (ISO/IEC 27001 6.1.3); record it in 8B with the risk owner, the approver set for Low and the review date from the period set in 8A. Sheet 4 tracks the treatment target date; overdue High or Severe treatments feed K13. Indicators (6): K07 Approval-rate gap between customer groups; K12 AI-related customer complaints.

Step	Example
If it happens (10)	Unfair outcomes are not usually a cyber incident. Handle complaints through the standard process and offer the two-choice review route (AI Guideline 21.2-21.3). If the outcome amounts to a serious AI incident, report it to QCB as in CB09.

D.3 Payment-support AI agent (AS02)

Step	Example
AI system (5A)	AI-05 Payment-support AI agent (AA07): rated C3 Secret / Confidential, I3, A2; aggregate level High. NIA v2.1: all baseline (*) statements apply, plus two or more additional controls per applicable domain, by risk assessment (2.3). Rated on the most sensitive system it can act on (payments, which hold SFI): C3 as the highest tier in this example (substitute the actual top tier); integrity is critical.
Scenario (4)	AS02 (asset type AA07 AI agent and its tools): An instruction hidden in an incoming email makes a payment-support agent change a beneficiary without approval. Threat AT01 Prompt injection (direct or indirect); vulnerability AV04 Excessive permissions for AI agents; no human approval for high-impact actions. Main consequence area: Financial (organisation).
Rating (example)	The bank rates the risk on its own scale; the mapping in 9B gives the national band High. High and Severe risks are reported to NCSA out of band: notify immediately, detailed report within 48 hours (EISRMF).
Approval and appetite (8A)	EISRMF meaning of High: Immediate intervention. Treatment plan required. Approver: the role the bank set for High in 8A, in addition to the risk owner. If the bank set Medium as the highest acceptable band for Financial (organisation), sheet 4 shows "Above appetite" and the risk is escalated to the decision level the bank set in 8A (section C).
Treatment (5)	Mitigate with C11 Agent limits, human approval and stop switch, C09 Input protection, CB08 Guard rails for fully autonomous AI. QCB rows supported: Q19 (13.1, 13.3); Q22 (13.7-13.8); Q29 (17.4-17.7). NIA baseline (*) statements supported: AM 3; CM 4.
Residual risk, acceptance and monitoring (8B, 6)	Target residual band Low (example). The risk owner approves the treatment plan and accepts the residual risk (ISO/IEC 27001 6.1.3); record it in 8B with the risk owner, the approver set for Low and the review date from the period set in 8A. Sheet 4 tracks the treatment target date; overdue High or Severe treatments feed K13. Indicators (6): K11 Agent actions blocked by guard rails; K13 Open High or Severe AI risks past their treatment date.
If it happens (10)	A cyber incident with possible fraud loss: treat it as High until downgraded (Incident Reporting Guideline 6.1.1) and call the QCB Hotline within 1 hour (6.2-6.3). A critical incident goes to QCB and the relevant governmental authorities within 1 hour (Technology Risks circular 8.2.10) and to NCSA within 2 hours (NIA IM 8); whether 8.2.10 covers NCSA is an open point (1 hour suggested until confirmed).